สรุปการเชื่อมต่อ API

Django REST Framework — ระบบร้านค้าอาหารออนไลน์

ไฟล์ API หลัก	myapp/api.py
ลงทะเบียน URL	myapp/urls.py : path('api/', include(api_urlpatterns))
จุดรวม (Prefix)	/api/
วงจร Endpoint	15 กลุ่ม
การยืนยันตัวตน	SessionAuthentication
การแบ่งหน้า	PageNumberPagination (20 รายการ/หน้า)
จำกัดอัตรา (Throttle)	reservation: 5/ชม. | notification: 60/นาที

ภาพรวมการออกแบบ

สถานะแบบบังคับ (Read-only)	orders.status, orders.payment_method, orders.paid_at ถูกห้ามแก้ผ่าน API กันผู้ใช้ PATCH ให้ออเดอร์ตัวเอง 'จ่ายแล้ว' โดยไม่ต้องจ่าย
แยกสิทธิ์ตามบทบาท	ระบุชัดเจนทุก ViewSet ว่าใครอ่านได้/เขียนได้ (ทุกคน / ล็อกอิน / เฉพาะเจ้าของ / เฉพาะ Admin)
กรองข้อมูลส่วนบุคคล	Delivery ซ่อนชื่อ/เบอร์/ที่อยู่ สำหรับผู้ใช้ทั่วไป (ข้อมูลผู้รับแบบ Mask)
ป้องกันการแก้ย้อนหลัง	points/transactions เป็น read-only (กันแก้ ledger), รีวิวลบได้เฉพาะเจ้าของ
กันสแปม/โจมตี	Throttle การจองโต๊ะและแจ้งเตือน, สร้าง data ของผู้ใช้คนอื่นไม่ได้ (ผูก created_by/owner)
เผยแพร่ข้อมูลสาธารณะ	เมนู/หมวดหมู่/เครื่องเคียง/คูปอง/สิทธิ์แลกคะแนน อ่านได้โดยไม่ต้องล็อกอิน
Integration LINE	จองโต๊ะสำเร็จ -> announce_new_reservation ส่ง LINE Notify (myapp/services.py:105)

ตารางรวม Endpoint ทั้งหมด

URL (ภายใต้ /api/)	Method / Action	สิทธิ์การเข้าถึง
categories	GET ☐	เข้าชมได้ทุกคน
menus	GET ☐ | POST | PUT/PATCH | DELETE ☐	อ่าน: ทุกคน | สร้าง/แก้/ลบ: เฉพาะ Admin
addons	GET ☐ | POST | PUT/PATCH | DELETE ☐	อ่าน: ทุกคน | สร้าง/แก้/ลบ: เฉพาะ Admin
orders	GET ☐ | POST | PUT/PATCH ☐ | DELETE ☐ | apply_coupon ☐ | remove_coupon ☐	อ่าน/แก้: ล็อกอินแล้ว เห็นเฉพาะออเดอร์ตัวเอง (Staff เห็นทั้งหมด) | สร้าง: ล็อกอิน
deliveries	GET ☐ | POST | PUT/PATCH ☐ | DELETE ☐	อ่าน/สร้าง: ล็อกอิน (เฉพาะออเดอร์ตัวเอง) | แก้/ลบ: เฉพาะ Admin
reservations	GET ☐ | POST (ไม่ต้องล็อกอิน) | PUT/PATCH ☐ | DELETE ☐ | update_status ☐	สร้าง: ทุกคน (ไม่ล็อกอิน) | อ่าน: เจ้าของ/ล็อกอิน, Staff เห็นทั้งหมด | แก้/ลบ/เปลี่ยนสถานะ: เฉพาะ Admin
coupons	GET ☐ | POST ☐ | PUT/PATCH ☐ | DELETE ☐ | validate ☐	อ่าน: ล็อกอินเห็นคูปองสาธารณะ+ของตัวเอง, แขกเห็นเฉพาะสาธารณะ | สร้าง/แก้/ลบ: เฉพาะ Admin
ingredients	GET ☐ | POST | PUT/PATCH | DELETE ☐	อ่าน: ทุกคน | สร้าง/แก้/ลบ: เฉพาะ Admin
recipes	GET ☐ | POST | PUT/PATCH | DELETE ☐	อ่าน: ทุกคน | สร้าง/แก้/ลบ: เฉพาะ Admin
reviews	GET ☐ | POST | PUT/PATCH | DELETE ☐	อ่าน: ทุกคน | เขียน/แก้/ลบ: ต้องล็อกอิน (ลบได้เฉพาะรีวิวตัวเอง)
points/rewards	GET ☐ | redeem ☐	อ่าน: ทุกคน (เห็นเฉพาะทีเปิดใช้งาน) | แลก: ต้องล็อกอิน

URL (ภายใต้ /api/)	Method / Action	สิทธิ์การเข้าถึง
points/transactions	GET ☐	ต้องล็อกอิน เห็นเฉพาะประวัติของตัวเอง (Staff เห็นทั้งหมด)
profile	me: GET ☐ | me: PATCH/PUT ☐	ต้องล็อกอิน (พบเฉพาะตัวเอง)
notifications	GET ☐ | read ☐ | read_all ☐	ต้องล็อกอิน เห็นเฉพาะแจ้งเตือนของตัวเอง (Staff เห็นส่วนกลางด้วย)
store	GET ☐	เข้าชมได้ทุกคน (Staff เห็นการตั้งค่าเพิ่มเติม)

1. categories — CategoryViewSet (myapp/api.py:151)

ประเภท: อ่านอย่างเดียว | ข้อความส่ง: -

รายละเอียด	รายการหมวดหมู่เมนูที่เปิดใช้งานอยู่ (is_active=True) เรียงตาม sort_order
สิทธิ์เข้าถึง	เข้าชมได้ทุกคน
ฟิลด์ (Fields)	id, name, slug, sort_order, is_active

2. menus — MenuItemViewSet (myapp/api.py:158)

ประเภท: CRUD | ข้อความส่ง: -

รายละเอียด	จัดการเมนูอาหาร รองรับการกรอง/เรียงลำดับโครงสร้าง Django ORM
สิทธิ์เข้าถึง	อ่าน: ทุกคน | สร้าง/แก้/ลบ: เฉพาะ Admin
ฟิลด์ (Fields)	id, name, category, category_display, price, spice_level, description, available, date_added, image

3. addons — AddOnViewSet (myapp/api.py:169)

ประเภท: CRUD | ข้อความส่ง: -

รายละเอียด	จัดการเครื่องเคียง/ออปชันเสริม (แสดงเฉพาะที่เปิดใช้งาน)
สิทธิ์เข้าถึง	อ่าน: ทุกคน | สร้าง/แก้/ลบ: เฉพาะ Admin
ฟิลด์ (Fields)	id, name, price, is_active

4. orders — OrderViewSet (myapp/api.py:180)

ประเภท: CRUD + Action | ข้อความส่ง: apply_coupon: {code} / remove_coupon: -

รายละเอียด	จัดการออเดอร์ สถานะ/ชำระเงินถูกบังคับเป็น read-only (กันแก้ status เอง)
สิทธิ์เข้าถึง	อ่าน/แก้: ล็อกอินแล้ว เห็นเฉพาะออเดอร์ตัวเอง (Staff เห็นทั้งหมด) | สร้าง: ล็อกอิน
ฟิลด์ (Fields)	id, order_type(+display), table_number(+display), status(+display), payment_method, created_at, paid_at, total_price, delivery_fee, is_paid, items, coupon_code, coupon_discount, discount_amount, discounted_total
Action (POST)	**POST /api/orders/{id}/apply_coupon/** ใช้คูปองกับออเดอร์ (คำนวณส่วนลด snapshot เช่นเดียวกับหน้าเว็บ) สำเร็จคืน {code, discount, total_after_discount}
Action (POST)	**POST /api/orders/{id}/remove_coupon/** เอารหัสคูปองออกจากออเดอร์ คืน {ok: True}

5. deliveries — DeliveryViewSet (myapp/api.py:272)

ประเภท: CRUD | ข้อความส่ง: -

รายละเอียด	ข้อมูลจัดส่ง — ผู้ใช้ทั่วไปเห็นข้อมูลผู้รับ/ที่อยู่แบบซ่อน (mask): ชื่อชื่อ 2 ตัวแรก, เบอร์ 3 ตัวแรก+2 ตัวท้าย, ที่อยู่ซ่อนทั้งหมด
สิทธิ์เข้าถึง	อ่าน/สร้าง: ล็อกอิน (เฉพาะออเดอร์ตัวเอง) | แก้/ลบ: เฉพาะ Admin
ฟิลด์ (Fields)	id, order, order_code, order_status, order_total, recipient_name, phone, address, fee, status(+display), rider_name, rider_phone, tracking_note, delivered_at, created_at

6. reservations — ReservationViewSet (myapp/api.py:408)

ประเภท: CRUD + Action | ข้อความส่ง: update_status: {status}

รายละเอียด	จองโต๊ะ — กันสแปมด้วย Throttle 5 ครั้ง/ชั่วโมง/ผู้ใช้ (ยกเว้น Staff) เมื่อสร้างสำเร็จจะแจ้งเตือนผ่าน LINE (announce_new_reservation)
สิทธิ์เข้าถึง	สร้าง: ทุกคน (ไม่ล็อกอิน) | อ่าน: เจ้าของ/ล็อกอิน, Staff เห็นทั้งหมด | แก้/ลบ/เปลี่ยนสถานะ: เฉพาะ Admin
ฟิลด์ (Fields)	id, customer_name, phone, party_size, table_number, reservation_date, reservation_time, notes, status(+display), created_at
Action (POST)	**POST /api/reservations/{id}/update_status/** เปลี่ยนสถานะการจอง (ยืนยัน/นั่งแล้ว/ยกเลิก) เฉพาะ Staff คืนข้อมูลการจองล่าสุด

7. coupons — CouponViewSet (myapp/api.py:456)

ประเภท: CRUD + Action | ข้อความส่ง: validate: {code, order_price}

รายละเอียด	ระบบคูปองส่วนลด รองรับทั้งคูปองสาธารณะและคูปองส่วนตัว (owner)
สิทธิ์เข้าถึง	อ่าน: ล็อกอินเห็นคูปองสาธารณะ+ของตัวเอง, แขกเห็นเฉพาะสาธารณะ | สร้าง/แก้/ลบ: เฉพาะ Admin
ฟิลด์ (Fields)	id, code, owner, owner_username, discount_type, value, min_order, max_uses, used_count, valid_from, valid_until, is_active
Action (POST)	**POST /api/coupons/validate/** ตรวจสอบคูปองก่อนใช้ คืน {code, discount_type, discount, min_order} — Staff ข้ามข้อจำกัดเจ้าของ

8. ingredients — IngredientViewSet (myapp/api.py:507)

ประเภท: CRUD | ข้อความส่ง: -

รายละเอียด	วัตถุดิบ/สต็อก เรียงตามชื่อ คำนวณสถานะ is_low_stock / is_out_stock อัตโนมัติ
สิทธิ์เข้าถึง	อ่าน: ทุกคน | สร้าง/แก้/ลบ: เฉพาะ Admin
ฟิลด์ (Fields)	id, name, unit, stock_qty, reorder_level, is_active, is_low_stock, is_out_stock

9. recipes — MenuIngredientViewSet (myapp/api.py:518)

ประเภท: CRUD | ข้อความส่ง: ?menu= (กรองรายการของเมนูนั้น)

รายละเอียด	สัดส่วนวัตถุดิบต่อเมนู (Recipe) รองรับกรองด้วย query param menu
สิทธิ์เข้าถึง	อ่าน: ทุกคน | สร้าง/แก้/ลบ: เฉพาะ Admin
ฟิลด์ (Fields)	id, menu, menu_name, ingredient, ingredient_name, ingredient_unit, quantity

10. reviews — ReviewViewSet (myapp/api.py:536)

ประเภท: CRUD | ข้อความส่ง: ?menu= (กรองรีวิวของเมนู)

รายละเอียด	รีวิว/ให้คะแนนเมนู 1-5 ดาว — ผู้ใช้ให้เมนูละ 1 ครั้ง (รีวิวซ้ำ = อัปเดตอันเดิม ด้วย update_or_create)
สิทธิ์เข้าถึง	อ่าน: ทุกคน | เขียน/แก้/ลบ: ต้องล็อกอิน (ลบได้เฉพาะรีวิวตัวเอง)

ฟิลด์ (Fields)	id, menu, username, rating (1-5), comment, created_at

11. points/rewards — PointRewardViewSet (myapp/api.py:573)

ประเภท: อ่านอย่างเดียว + Action | ข้อความส่ง: redeem: -

รายละเอียด	สิทธิ์แลกคะแนน แลกสำเร็จจะออกคูปองรหัส PTS-... ผูกเจ้าของ อายุ 30 วัน และตัดคะแนนผ่าน ledger
สิทธิ์เข้าถึง	อ่าน: ทุกคน (เห็นเฉพาะที่เปิดใช้งาน) | แลก: ต้องล็อกอิน
ฟิลด์ (Fields)	id, name, description, points_cost, discount_type, value, min_order, is_active
Action (POST)	**POST /api/points/rewards/{id}/redeem/** แลกคะแนนเป็นสิทธิ์ คืน {error, code, balance, reward{...}} — คะแนนไม่พอคืน 400

12. points/transactions — PointTransactionViewSet (myapp/api.py:626)

ประเภท: อ่านอย่างเดียว | ข้อความส่ง: -

รายละเอียด	ประวัติคะแนน (ledger) — read-only ทั้งหมด กันแก้ไขย้อนหลัง
สิทธิ์เข้าถึง	ต้องล็อกอิน เห็นเฉพาะประวัติของตัวเอง (Staff เห็นทั้งหมด)
ฟิลด์ (Fields)	id, user, points_change, balance_after, reason, reward, reward_name, created_at

13. profile — ProfileViewSet (myapp/api.py:638)

ประเภท: Action เดียว | ข้อความส่ง: PATCH me: multipart/form-data (avatar, cover)

รายละเอียด	โปรไฟล์ตัวเอง + ยอดคะแนน/สถานะสมาชิก — อัปเดต avatar/cover ด้วย multipart
สิทธิ์เข้าถึง	ต้องล็อกอิน (พบเฉพาะตัวเอง)
ฟิลด์ (Fields)	id, username, email, avatar, cover, membership_status, points, points_rate, discount_percent, free_delivery, max_favorites
Action (POST)	**GET /api/profile/me/** ดูโปรไฟล์ตัวเอง + คะแนน/สถานะสมาชิก/ส่วนลด
Action (POST)	**PATCH /api/profile/me/** แก้ไขโปรไฟล์ตัวเอง (avatar / cover ใช้ multipart/form-data)

14. notifications — NotificationViewSet (myapp/api.py:676)

ประเภท: อ่านอย่างเดียว + Action | ข้อความส่ง: -

รายละเอียด	รายการแจ้งเตือน — Throttle 60 ครั้ง/นาที เครื่องหมายอ่านแล้ว/อ่านทั้งหมด
สิทธิ์เข้าถึง	ต้องล็อกอิน เห็นเฉพาะแจ้งเตือนของตัวเอง (Staff เห็นส่วนกลางด้วย)
ฟิลด์ (Fields)	id, kind(+display), title, message, link, is_read, created_at
Action (POST)	**POST /api/notifications/{id}/read/** ทำเครื่องหมายว่าอ่านแล้ว คืน {ok: True}
Action (POST)	**POST /api/notifications/read_all/** อ่านทั้งหมด คืน {ok: True, updated: <จำนวน>}

15. store — StoreInfoView (myapp/api.py:705)

ประเภท: อ่านอย่างเดียว | ข้อความส่ง: -

รายละเอียด	ข้อมูลร้าน พิกัด/ค่าส่ง/แผนที่ — เผยแพร่สาธารณะ ห้ามรั่ว LINE token แต่ Staff เห็น promptpay_id, notification_email
สิทธิ์เข้าถึง	เข้าชมได้ทุกคน (Staff เห็นการตั้งค่าเพิ่มเติม)
ฟิลด์ (Fields)	name, lat, lng, address, fee_base, fee_per_km, free_delivery_over, maps_url + (Staff) auto_assign_enabled, auto_assign_grace_minutes, auto_release_minutes, promptpay_id, notification_email, notify_order, notify_reservation, notify_review

ข้อควรจำด้านสิทธิ์ (สรุป)

• อ่านได้ทุกคน (AllowAny / IsAuthenticatedOrReadOnly): categories, menus, addons, store, reviews (GET), points/rewards (GET)

• อ่านต้องล็อกอิน: profile, notifications, points/transactions

• เขียนต้องล็อกอิน: orders, deliveries (สร้าง), reviews (เขียน/แก้/ลบ), points/rewards (redeem), coupons (validate)

• เฉพาะ Admin (IsAdminUser): สร้าง/แก้/ลบ menus, addons, ingredients, recipes, coupons, reservations (แก้/ลบ/สถานะ), deliveries (แก้/ลบ)

• ทั้งหมดถูกปิดด้วย DEFAULT_PERMISSION_CLASSES = IsAuthenticatedOrReadOnly ที่ settings.py:220